

External Evidence Pack — Excerpt

SAMPLE

REDACTED

SECTIONS 1 · 2 · 4 · 5 · 6 · 11 · 12 · 13

Target: titanos.tech (own infrastructure) · **Generated:** 2026-06-24T02:48:56Z · **Operator:** Kyle Deligny · **ABN:** 34 318 502 254

This is the **externally-verifiable portion** of the 13-section Titanos Compliance Evidence Pack — generated from a real scan of my own infrastructure on 24 June 2026. The operational sections (privacy policy + ADM disclosure, NDB runbook, vendor risk register, M365 / Workspace hardening evidence, MFA enforcement screenshots, backup posture, patching cadence, staff access management, signed Essential Eight ML1 attestation, Privacy Act posture letter) are regenerated per engagement from the client's own operational data — they do not appear in this sample because fabricating those would defeat the purpose. Request the redacted full version on a fit call.

01 — Executive summary

External scan against titanos.tech on 24 June 2026. Four open ports (80, 443, 8080, 8443), all Cloudflare-fronted; origin (GitHub Pages) not directly reachable. TLS posture is strong (Google Trust Services WE1, ECDSA P-256, TLS 1.3, HSTS preload). Email auth is at the strongest practical configuration (SPF strict -all, DMARC p=reject pct=100, DKIM published). Five findings logged, all Info or Low severity — top item is the absence of CAA records, which should be published to constrain CA issuance scope.

Headline scores

AREA	POSTURE	NOTES
Edge TLS	Strong	TLS 1.3 only at this edge; AES-256-GCM; ECDHE P-256.
Email auth	Strong	SPF -all, DKIM, DMARC p=reject.
HSTS	Strong	Preload + includeSubDomains, max-age 1 year.
CSP / Permissions-Policy	Partial	CSP via meta tag (see F-02). Permissions-Policy absent (F-03).
CAA	Missing	No CAA RRset (F-01).
Open ports / origin exposure	OK	All ports terminate at Cloudflare edge; origin shielded.

02 — Scope & methodology

External, passive-style attack surface assessment. No authentication attempts, no exploitation, no DoS, no exfiltration. Every command in this report can be reproduced from a public network by anyone — that is the point.

- Port + service discovery: `nmap -sV -Pn -p 80,443,8080,8443 titanos.tech`
- TLS handshake: `openssl s_client -connect titanos.tech:443 -servername titanos.tech`
- DNS lookups via `dnspython` against 8.8.8.8 / 1.1.1.1 (A / AAAA / TXT / MX / CAA / NS, plus `_dmarc` and `google._domainkey`)
- Response headers: `curl -I https://titanos.tech/` (and `/scan`, `/compliance`)
- Reasoning window: 90 days responsible disclosure on any L+ finding before publication.

04 — Open ports + services

PORT	STATE	SERVICE	FINGERPRINT
80/tcp	open	http	cloudflare
443/tcp	open	ssl/https	cloudflare
8080/tcp	open	http-proxy	cloudflare
8443/tcp	open	ssl/https-alt	cloudflare

Resolved IP: 172.67.217.202 (and 1 sibling A address). Origin behind Cloudflare edge — origin server not directly exposed on the public internet from this vantage point.

05 — TLS / SSL posture

ISSUER	Google Trust Services (WE1)
SUBJECT	CN=titanos.tech
SAN	titanos.tech, *.titanos.tech
VALID	2026-06-01 04:00:52 UTC → 2026-08-30 04:45:54 UTC (90-day lifecycle)
PUBLIC KEY	ECDSA P-256 (prime256v1)
SIGNATURE ALG	ecdsa-with-SHA256
TLS VERSION	TLSv1.3
NEGOTIATED CIPHER	TLS_AES_256_GCM_SHA384
OCSP RESPONDER	http://o.pki.goog/s/we1/oSM
VERIFICATION	0 (ok)

06 — DNS + email security

A / AAAA / NS / MX

A	172.67.217.202, 104.21.94.4 (Cloudflare)
AAAA	2606:4700:3036::6815:5e04, 2606:4700:3033::ac43:d9ca (Cloudflare)
NS	venus.ns.cloudflare.com., andy.ns.cloudflare.com.
MX	1 aspmx.l.google.com. 5 alt1.aspmx.l.google.com. 5 alt2.aspmx.l.google.com. 10 alt3.aspmx.l.google.com. 10 alt4.aspmx.l.google.com.

Email authentication

SPF	<pre>v=spf1 include:_spf.google.com include:_spf.mx.cloudflare.net -all</pre>
DKIM (GOOGLE._DOMAINKEY)	Published (RSA key found)
DMARC	<pre>v=DMARC1; p=reject; rua=mailto:kyle@titanos.tech; ruf=mailto:kyle@titanos.tech; pct=100</pre>
CAA	NO CAA RRset — see finding F-01

11 — HTTP security headers (live)

HEADER	VALUE
strict-transport-security	max-age=31536000; includeSubDomains; preload
x-frame-options	SAMEORIGIN
x-xss-protection	1; mode=block
referrer-policy	same-origin
expect-ct	max-age=86400, enforce

HEADER	VALUE
x-content-type-options	(absent in response — see finding 6.3)
content-security-policy	(absent as response header — set via <meta> in layout.tsx, see finding 6.2)
permissions-policy	(absent — see finding 6.4)
server	cloudflare

Captured via `curl -sI https://titanos.tech/` on the generation date. Response served from Cloudflare edge (BNE region) with GitHub Pages as origin.

09 — You-vs-host responsibility split

YOU CONTROL (DNS + PAGE)

- DNS records (SPF / DKIM / DMARC / CAA / NS)
- Domain registrar lock + 2FA
- CSP via <meta> in app/layout.tsx
- Application-level XSS / CSRF / input validation
- Build pipeline + repo access
- Privacy policy + ADM disclosure content

HOST CONTROLS (CLOUDFLARE + GITHUB PAGES)

- Edge TLS termination + cipher policy
- HSTS header injection (CF Managed Transform)
- X-Frame-Options + X-XSS-Protection (CF MT)
- Permissions-Policy header (CF MT — currently absent, F-03)
- DDoS / WAF
- Origin server hardening (GitHub Pages)

10 — Prioritised remediation (findings)

Five findings logged. All **Info** or **Low** severity. Listed in order of prioritised remediation effort vs risk reduction.

F-01 CAA records not published

LOW

SECTION 06 DNS hygiene

EVIDENCE CAA lookup against authoritative resolvers timed out; no CAA RRset returned for titanos.tech via 8.8.8.8 or 1.1.1.1.

IMPACT Without a CAA record, any publicly-trusted CA can issue a certificate for titanos.tech. Publishing CAA constrains the set of CAs allowed to issue, reducing the blast radius of a rogue-issuance event.

RESPONSIBILITY YOU (DNS provider — Cloudflare DNS).

REMEDIATION

Publish CAA records authorising the two CAs actually in use (Google Trust Services for current cert; optionally Let's Encrypt for fallback). Example:

```
titanos.tech. CAA 0 issue "pki.goog"
titanos.tech. CAA 0 issue "letsencrypt.org"
titanos.tech. CAA 0 iodef "mailto:kyle@titanos.tech"
```

F-02 Content-Security-Policy absent as a response header

INFO

SECTION 11 HTTP security headers

EVIDENCE GET https://titanos.tech/ returns no Content-Security-Policy header. CSP is configured via <meta http-equiv> in app/layout.tsx — visible to browsers but a response-header CSP is preferred (covers cases where the meta is parsed late or stripped by a proxy).

IMPACT Browser-side CSP enforcement still works because the meta tag is present, so this is informational rather than a defect. Moving CSP to a response header via Cloudflare Transform Rules is a hardening improvement.

RESPONSIBILITY SHARED — policy is yours; injection point is Cloudflare.

REMEDIATION

Add a Cloudflare Managed Transform Rule (or worker) that injects Content-Security-Policy on the static asset response. Mirror the value currently in app/layout.tsx.

F-03 Permissions-Policy not advertised

INFO

SECTION 11 HTTP security headers

EVIDENCE No Permissions-Policy header present on / or /scan or /compliance. The site does not currently use camera, microphone, geolocation, or payment APIs, so absence does not expose anything today.

IMPACT Low — best-practice hardening for sites that do use sensitive browser APIs. Adding an explicit deny-all-by-default Permissions-Policy guards against future-feature drift.

RESPONSIBILITY HOST (Cloudflare Transform Rule).

REMEDIATION

Add via Cloudflare Transform Rule:
Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=()

F-04 Cloudflare-fronted ports 8080 + 8443 open

INFO

SECTION 04 Open ports + services

EVIDENCE nmap -sV reports 80, 443, 8080, 8443 open and all responding as 'cloudflare' — these are Cloudflare's standard HTTP/HTTPS alt-ports, fronted by the same edge that serves 80/443. Cloudflare returns HTTP 403 on 8443 for arbitrary requests (no origin behind the alt-port).

IMPACT Informational — these are Cloudflare's default open alt-ports, not origin-server ports. The GitHub Pages origin is not directly exposed.

RESPONSIBILITY HOST (Cloudflare).

REMEDIATION

No action required. If a stricter posture is desired, Cloudflare Page Rules can return 444 on 8080/8443.

F-05 expect-ct header still emitted

INFO

SECTION 11 HTTP security headers**EVIDENCE** Response includes expect-ct: max-age=86400, enforce. The Expect-CT header was deprecated in favour of Certificate Transparency being mandatory for all publicly-trusted certs.**IMPACT** None — deprecated but not harmful. Modern browsers ignore it.**RESPONSIBILITY** HOST (Cloudflare).**REMEDIATION**

Optional cleanup: drop Expect-CT from the Cloudflare Transform Rules. CT enforcement is now baseline.

12 — Evidence appendix (reproducible commands)

Every finding above can be re-derived from these commands. Run them yourself from any internet-connected machine.

```
nmap -sV -Pn -p 80,443,8080,8443 titanos.tech
nmap -sV -Pn --top-ports 100 titanos.tech

echo | openssl s_client -connect titanos.tech:443 -servername titanos.tech 2>/dev/null \
| openssl x509 -noout -text

# DNS (python dnspython, or `dig`/`drill` equivalents):
python3 -c "import dns.resolver; r=dns.resolver.resolve('titanos.tech','TXT');
print('\n'.join(map(str,r)))"

python3 -c "import dns.resolver; r=dns.resolver.resolve('_dmarc.titanos.tech','TXT');
print('\n'.join(map(str,r)))"

python3 -c "import dns.resolver;
r=dns.resolver.resolve('google._domainkey.titanos.tech','TXT');
print(str(r[0])[200])"

python3 -c "import dns.resolver; r=dns.resolver.resolve('titanos.tech','CAA');
print('\n'.join(map(str,r)))" # expect NoAnswer until F-01 is remediated

curl -sI https://titanos.tech/ | grep -iE 'strict-transport|content-security|x-frame|x-
xss|referrer|permissions|expect-ct'
```

13 — Responsible disclosure terms

I scan my own infrastructure and any domain I am authorised to scan (every paying engagement, plus AU/NZ/SG businesses that have requested a free external scan via titanos.tech/scan). On any third-party finding I publish externally, a **90-day responsible-disclosure window** applies — I notify the operator and wait at least 90 days before any public reference. The scan methodology is external-only: no auth attempts, no exploits, no DoS, no exfiltration. See titanos.tech/methodology for the full technical scope and the published reproducibility format.

Attestation note

This sample carries the same shape, format, and reproducibility discipline as every compliance-engagement evidence pack. The operational sections that are absent here (privacy policy, NDB runbook, vendor risk register, M365 hardening evidence, MFA enforcement screenshots, backup posture, patching cadence, staff access management, Essential Eight Maturity Level 1 self-attestation, Privacy Act posture letter) are produced from each client's own operational data on their engagement — fabricating sample copies of those would be a straight-out breach of the truth guardrail this practice runs on. Request the redacted full version on a fit call.

Kyle Deligny · ABN 34 318 502 254 · titanos.tech

Issued 2026-06-24T02:48:56Z. Re-run any command above to independently verify any claim in this document.